Brezžična in Mobilna Omrežja
Študijsko leto 2025/2026

Ranljivosti Bluetooth naprav

Končno poročilo seminarske naloge

Žan Perat
Vpisna št. 63230239

Ljubljana, 22. april 2026

Kazalo

1 Uvod in motivacija **3**

2 Opis uporabljene strojne in programske opreme **3**

3 Tipi napadov na bluetooth naprave **3**

3.1 BlueSnarfing 3

3.2 MAC address spoofing 3

3.3 BlueBorne 3

3.4 Reflection Attack 4

3.5 Denial of Service (DoS) 4

3.6 Bluejacking 4

3.7 Bluesmacking 4

3.8 PIN Brute Force 4

4 Eksperimentalna analiza Bluetooth napadov **5**

4.1 Hcitool 5

4.2 Bluetoothctl 5

4.3 Sdptool 6

4.4 Še nekaj osnovnih ukazov 7

4.5 CVE-2023-45866 8

4.5.1 Rezultati testiranja 9

4.5.2 Ugotovitve 10

4.6 Denial of Service (DoS) 10

5 Zaključek **12**

1 Uvod in motivacija

Opis problema, ki ga naša rešitev reši.

2 Opis uporabljene strojne in programske opreme

Kratek opis uporabljene strojne in programske opreme.

3 Tipi napadov na bluetooth naprave

3.1 BlueSnarfing

BlueSnarfing je neavtoriziran dostop do informacij na brezžični napravi prek Bluetooth povezave. Ta napad omogoča pridobitev dostopa do koledarja, telefonskega imenika, e-pošte, SMS sporočil in drugih osebnih podatkov. Pogosto izkorišča profil OBEX Push (Object Exchange), ki ob nepravilni konfiguraciji razkrije podatke brez potrditve uporabnika.

3.2 MAC address spoofing

Ta napad se lahko zgodi, ko se napravi dogovarjata za varne ključe, s katerimi bosta komunicirali, torej mora biti napadalec že na začetku prisoten. Napadalec ponaredi (spoofa) MAC naslov zaupanja vredne naprave in tako prelisiči ciljno napravo, da se poveže z njegovo namesto s prvotno napravo. S tem lahko prestreže komunikacijo ali se lažno avtenticira, ne da bi razkril svoj pravi naslov.

3.3 BlueBorne

BlueBorne je kolekcija več Bluetooth napadov, ki izkoriščajo napake v Bluetooth kopici (stack), zlasti v BlueZ (Linux), Androidu, Windows in iOS. Z uporabo prekoračitve medpomnilnika (buffer overflow) ali drugih pomnilniških napak lahko napadalec na ciljni napravi izvede poljubno nezaželeno kodo, brez da bi bil seznanjen z napravo ali da bi ta zahtevala paring.

3.4 Reflection Attack

Do reflection napada pride, ko napadalec prestreže avtentikacijske podatke (npr. kriptografske izzive in odgovore) med dvema napravama in jih nato ponovi (reflektira) tretji napravi ali isti napravi v drugem času. S tem ne razkrije nobenih lastnih informacij in lahko pridobi neavtoriziran dostop do storitev, kot da bi bil legitimen uporabnik, medtem ko se predstavlja za nekoga drugega.

3.5 Denial of Service (DoS)

Pri tem napadu napadalec poskuša prekiniti povezavo med dvema napravama ali narediti Bluetooth vmesnik popolnoma neuporaben. To doseže s pošiljanjem velikega števila paketov (npr. zahtevkov L2CAP, SDP ali praznih paketov), kar povzroči preobremenitev in sesutje Bluetooth kopice. Posledično naprava ne more več vzpostavljati novih povezav ali pa se obstoječe prekinejo.

3.6 Bluejacking

Bluejacking je pošiljanje nezaželenih sporočil prek Bluetootha. Napadalec uporabi protokol OBEX (lahek komunikacijski protokol za pošiljanje binarnih datotek), da pošlje kratko sporočilo svojemu imeniku, ki se prikaže na zaslonu žrtve. Čeprav je bluejacking večinoma nedolžna potegavščina, se lahko zlorabi za namene socialnega inženiringa ali širjenja zlonamerne vsebine.

3.7 Bluesmacking

Bluesmacking je oblika DoS napada, specifična za Bluetooth. Napadalec pošlje veliko število lažnih zahtevkov L2CAP echo (ping) na ciljno napravo, ki jih ta ne more pravilno obdelati. To povzroči preobremenitev procesorja in posledično izpad Bluetooth storitev.

3.8 PIN Brute Force

Pri starejših napravah z Bluetooth 2.0 in nižje se uporablja kratek PIN (običajno 4–6 števk). Napadalec lahko s prisluškovanjem parjenju prestreže

izmenjane pakete in nato s programom (npr. ‘btcrack‘) poskusi vse možne kombinacije PIN kode. Ko jo odkrije, lahko izračuna skupne ključe in dešifrira celotno komunikacijo.

4 Eksperimentalna analiza Bluetooth napadov

V tem delu smo preučili različne bluetooth napade na različnih napravah.

Najprej pa rabimo spoznati par orodij, ki jih bomo uporabljali poleg teh napadov.

4.1 Hcitool

`hcitool` je ukaz v Linuxu, ki omogoča upravljanje in nadzor Bluetooth povezav na nizki ravni (Host Controller Interface - HCI). Je del paketa `BlueZ`, najbolj razširjene Bluetooth implementacije za Linux, ki mu omogoča neposredno komunikacijo s strojno opremo (adapterjem). V spodnji tabeli so predstavljeni najpogosteje uporabljeni ukazi, ki jih bom uporabljal v napadih in njihov namen.

Ukaz	**Opis**
`hcitool dev`	Prikaže seznam lokalnih Bluetooth adapterjev (npr. `hci0`).
`hcitool scan`	Skenira vse odkrivajoče se naprave v dosegu in izpiše njihov MAC naslov ter ime.
`hcitool info <MAC>`	Pridobi podrobne informacije (ime, razred, LMP verzijo, značilnosti).
`hcitool rssi <MAC>`	Prikaže jakost signala (RSSI) za povezano napravo.
`hcitool lq <MAC>`	Prikaže kakovost povezave (Link Quality).
`hcitool lescan`	Skenira BLE (Bluetooth Low Energy) naprave.
`hcitool leinfo <MAC>`	Pridobi informacije o BLE napravi.

Tabela 1: Pregled ukazov orodja `hcitool`

4.2 Bluetoothctl

`bluetoothctl` je sodobno interaktivno orodje za upravljanje Bluetooth naprav v Linuxu. Prav tako je del paketa `BlueZ`, vendar za razliko od zastarelega `hcitool` ponuja višjenivojski vmesnik, ki podpira vse sodobne Blueto-

oth profile in storitve, vključno s poenostavljenim seznanjanjem (pairing), zaupanjem naprav (trust) in upravljanjem BLE naprav. Uporablja se v interaktivnem načinu, kjer uporabnik vnaša ukaze v lastno lupino.

V spodnji tabeli so predstavljeni najpogosteje uporabljeni ukazi znotraj `bluetoothctl`.

Ukaz	**Opis**
`power on`	Vklopi Bluetooth adapter.
`power off`	Izklopi Bluetooth adapter.
`scan on`	Začne skenirati naprave v dosegu.
`scan off`	Ustavi skeniranje.
`devices`	Prikaže seznam vseh naprav, ki jih je adapter zaznal.
`pair <MAC>`	Začne postopek seznanjanja z napravo z danim MAC naslovom.
`trust <MAC>`	Označi napravo kot zaupanja vredno (samodejno dovoli povezave brez ponovnega seznanjanja).
`connect <MAC>`	Vzpostavi povezavo s predhodno seznanjeno napravo.
`disconnect <MAC>`	Prekine povezavo z napravo.
`remove <MAC>`	Odstrani napravo iz seznama seznanjenih (pozabi jo).
`info <MAC>`	Prikaže podrobne informacije o napravi (ime, razred, UUID, stanje povezave).
`show`	Prikaže informacije o lokalnem Bluetooth adapterju.
`agent on`	Vklopi agenta za upravljanje PIN kod in potrditev parjenja.
`default-agent`	Nastavi trenutnega agenta kot privzetega.
`exit`	Zapre `bluetoothctl`.

Tabela 2: Pregled ukazov orodja `bluetoothctl`

Orodje `bluetoothctl` je danes standardni način za upravljanje Bluetooth povezav v Linuxu in popolnoma nadomešča starejša orodja, kot so `hcitool`, `rfcomm` in `sdptool`. Omogoča tudi delo z BLE napravami prek podukazov, kot sta `ble` in `advertise`.

4.3 Sdptool

`sdptool` je ukaz v Linuxu, ki omogoča poizvedovanje in upravljanje strežnikov protokola SDP (Service Discovery Protocol). Je del paketa `BlueZ` in omogoča iskanje specifičnih storitev na oddaljenih napravah ter pregled vseh razpoložljivih storitev prek ukaza `browse`. SDP je ključnega pomena za odkrivanje storitev, ki jih naprava ponuja (npr. prenos datotek, dostop

do telefonskega imenika, brezžični zvok). V spodnji tabeli je predstavljen najpomembnejši ukaz orodja `sdptool`.

Ukaz	Opis
`sdptool browse <MAC>`	Pregled vseh razpoložljivih storitev na oddaljeni napravi z danim MAC naslovom. Izpiše imena storitev, kanale in profile.

Tabela 3: Pregled ukazov orodja `sdptool`

Orodje `sdptool` je danes označeno kot zastarelo in ga v sodobnih distribucijah Linuxa nadomeščata orodji `bluetoothctl` in `btmgmt`. Kljub temu pa ostaja uporabno za poglobljeno diagnostiko in razumevanje protokola SDP, zlasti pri starejših napravah in sistemih.

4.4 Še nekaj osnovnih ukazov

Ukaz	Opis
`hciconfig -a`	Prikaže podrobne informacije o vseh Bluetooth vmesnikih (npr. `hci0`), vključno z MAC naslovom, stanjem (UP/DOWN), različico HCI, imenom naprave in razredom.
`hciconfig hci0 up`	Aktivira (vklopi) Bluetooth vmesnik `hci0`. Po tem ukazu je adapter pripravljen za skeniranje in povezovanje.
`hciconfig hci0 down`	Deaktivira (izklopi) Bluetooth vmesnik `hci0`.
`hciconfig hci0 reset`	Ponastavi Bluetooth vmesnik `hci0`. Uporabno, kadar adapter ne odziva pravilno.
`hciconfig hci0 name "ime"`	Spremeni lokalno ime Bluetooth naprave (prikazano ob skeniranju).
`systemctl start bluetooth`	Zažene Bluetooth storitev (oz. `bluetooth.service`) v sistemu.
`systemctl stop bluetooth`	Ustavi Bluetooth storitev.
`systemctl restart bluetooth`	Ponovno zažene Bluetooth storitev – uporabno po spreminjanju konfiguracije ali odpravljanju težav.
`systemctl enable bluetooth`	Nastavi, da se Bluetooth storitev samodejno zažene ob zagonu sistema.
`systemctl status bluetooth`	Prikaže trenutno stanje Bluetooth storitve (ali je aktivna, morebitne napake).

Tabela 4: Pregled ukazov `hciconfig` in `systemctl` za Bluetooth

Sedaj smo pregledali vse osnovne ukaze in kako se dela z bluetoothom na linux napravah, tako da lahko začnemo z dejanskimi napadi.

4.5 CVE-2023-45866

Prvi napad, ki sem ga izvedel, temelji na ranljivosti CVE-2023-45866. V sklopu `BlueZ` lahko neavtenticirana HID (Human interface device) naprava v vlogi periferne enote vzpostavi šifrirano povezavo in pošilja poročila HID tipkovnice, ne da bi centralna naprava zahtevala kakršno koli interakcijo uporabnika. S tem je možno injicirati HID sporočila (npr. pritiske tipk) brez vednosti uporabnika. Ta napad sem testiral na treh telefonskih napravah in sicer:

- OPPO Find X5 (bluetooth 5.3)
- Samsung Galaxy S7 edge (bluetooth 4.2)
- Samsung Galaxy Ace S5830 (bluetooth 3.0)

Mogoče poznate Rubber Ducky, to je USB ključek, ki na površini zgleda kot vsak drug ključek, ampak ko ga priključiš v računalnik se predstavlja kot da je human interface device (npr. tipkovnica) in začne izvajati neko kodo, ker je računalnik narejen tako da zaupa človeku to kodo izvede. Kaj če bi to lahko naredil kdorkoli samo z dostopom do bluetootha? Izkaže se da s CVE-2023-45866 lahko točno to dosežemo. Napisal sem 2 bolj enostavna skripta za Rubber ducky in uporabil malo prilagojeno kodo BlueDucky (https://github.com/pentestfunctions/BlueDucky) en od teh skriptov je bolj satiričen in sicer predvaja pesem Rick Astley - Never gonna give you up, drugi pa gre v nastavitve telefona.

```
REM Rickroll Android
DELAY 2000

REM Open Chrome
GUI b
DELAY 500
CTRL l
STRING https://www.youtube.com/watch?v=dQw4w9WgXcQ
ENTER
DELAY 3000
```

```
REM Go to settings
DELAY 2000
GUI i
DELAY 500
```

4.5.1 Rezultati testiranja

Za vsako od treh naprav sem poskusil izvesti dva različna DuckyScripta: prvi je prek brskalnika Chrome predvajal Rickroll video, drugi pa je poskušal odpreti sistemske nastavitve. Rezultati so prikazani v tabeli 5.

Naprava	**Bluetooth različ-ica**	**Rickroll**	**Odpiranje nastavitev**
OPPO Find X5	5.3	Uspelo	Uspelo
Samsung Galaxy S7 edge	4.2	Uspelo	Uspelo
Samsung Galaxy Ace S5830	3.0	Neuspešno	Neuspešno

Tabela 5: Uspešnost injiciranja tipk prek CVE-2023-45866 na testiranih napravah

Pri obeh novejših napravah (OPPO Find X5 in Samsung S7 edge) je napad deloval brez vsakršnega opozorila ali zahteve po potrditvi, vendar le zato, ker sta bili napravi že predhodno seznanjeni (paired) z mojim Bluetooth adapterjem. Telefon je takoj sprejel povezavo s HID tipkovnico in izvedel vnešene ukaze, saj je zaupanje med napravama že obstajalo.

Omeniti velja, da je bila ranljivost CVE-2023-45866 v času testiranja že uradno popravljena (patched). Pred popravkom pa napad sploh ni zahteval predhodnega seznanjanja – dovolj je bilo, da je napadalec vzpostavil HID povezavo brez kakršne koli predhodne interakcije z uporabnikom.

Če bi imel napadalec na voljo naprednejšo strojno opremo, kot je `Ubertooth One`, bi lahko prisluškoval (sniffal) Bluetooth komunikacijo in posnel MAC naslov naprave, ki ji telefon že zaupa. Nato bi se lahko predstavljal kot ta naprava (MAC address spoofing) in s tem izvedel enake ukaze, ne da bi bilo potrebno kakršno koli predhodno seznanjanje – telefon bi namreč povezavo sprejel, ker bi verjel, da komunicira z že znano in zaupano napravo.

Pri najstarejši napravi, Samsung Galaxy Ace S5830 (Bluetooth 3.0), napad ni uspel. Telefon se ni odzval na poskuse vzpostavitve HID povezave. Razlog

je v tem, da ta naprava podpira le zelo omejen nabor Bluetooth storitev in profilov – med drugim ne ponuja profila HID (Human Interface Device) prek Bluetootha. Poleg tega ima odprtih le nekaj RFCOMM kanalov (predvsem za Headset in Handsfree), zato preprosto ni imela ustreznega vstopnega mesta za tovrstni napad.

4.5.2 Ugotovitve

Na podlagi opravljenih testov lahko zaključim naslednje:

- Ranljivost CVE-2023-45866 omogoča injiciranje tipk na vseh novejših Android napravah (Bluetooth 4.2 in novejši), ki niso bile popravljene. Napad poteka popolnoma brez interakcije uporabnika – žrtev ne vidi nobenega obvestila o parjenju ali povezovanju.
- Čeprav je bilo za prvo povezavo včasih treba potrditi dovoljenje za seznanitev (pairing), bi to oviro lahko zaobšli z uporabo naprednejše strojne opreme, kot je `Ubertooth One`. S slednjo bi lahko ponaredili (spoofali) MAC naslov naprave, ki ji telefon že zaupa, in se tako predstavljali kot že prej potrjena naprava.
- Starejše naprave (Bluetooth 3.0 in nižje) praviloma niso ranljive za ta napad, ker ne podpirajo HID profila prek Bluetootha oziroma nimajo dovolj odprtih storitev, prek katerih bi lahko vzpostavili takšno povezavo.

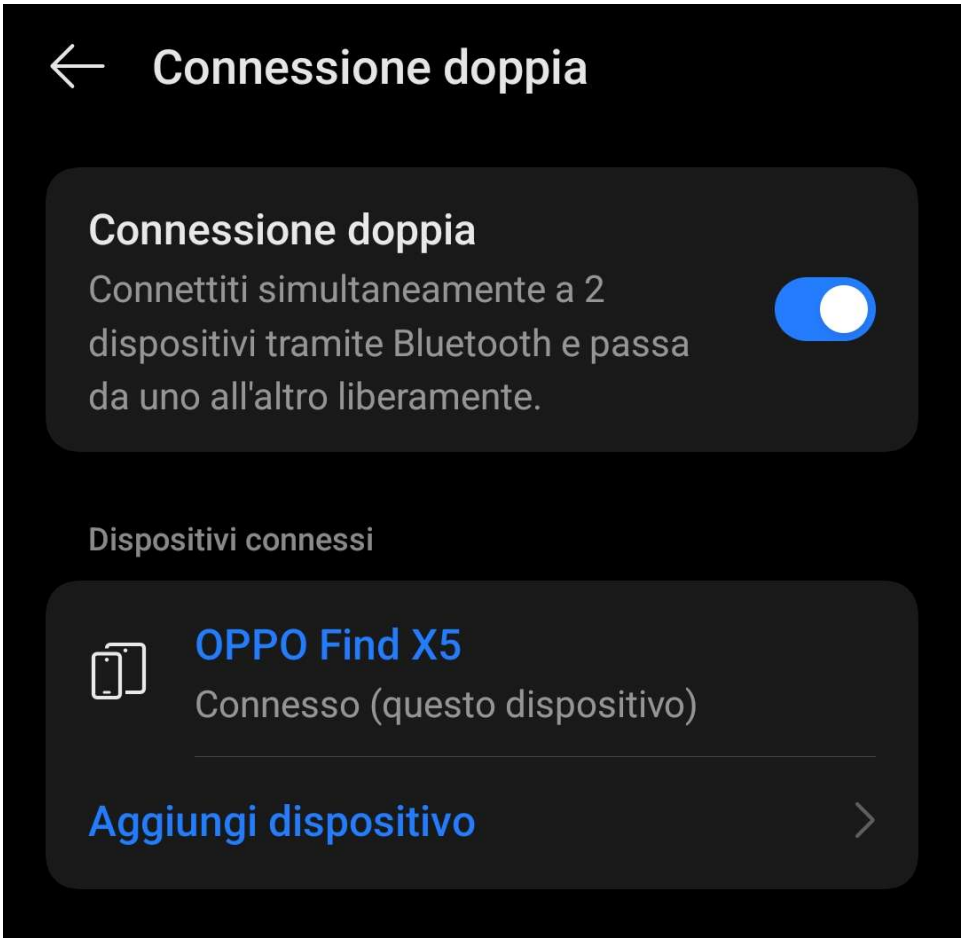
Napad CVE-2023-45866 tako predstavlja resno varnostno tveganje za vse neposodobljene Android naprave, saj napadalcu omogoča popoln nadzor nad vnosom tipk – od odpiranja zlonamernih spletnih strani do izvajanja sistemskih ukazov.

4.6 Denial of Service (DoS)

V tem napadu bom poskušal prekiniti povezavo med dvema napravama, in sicer med brezžičnimi slušalkami OPPO Enco X2 in telefonom OPPO Find X5. To bom poskušal doseči z ukazom `l2ping`, kasneje pa bom ta ukaz izvajal vzporedno (z več nitmi), da bom poslal večje število paketov.

Najprej se pogovorimo o pripravah na ta napad. Veliko boljših brezžičnih slušalk ima zaščito pred tovrstnimi napadi, med njimi tudi OPPO Enco X2. Te se varujejo tako, da preprosto zavržejo vse pakete, ki ne prihajajo iz

naprave, s katero so trenutno povezane. Seveda bi se z dovolj veliko količino paketov tudi ta zaščita lahko sesula. Ena dobrih lastnosti teh slušalk pa je funkcija, ki dovoljuje, da sta nanje hkrati povezani dve napravi. To je lahko uporabno v zelo specifičnih primerih – na primer, če si s partnerjem izmenjujeta predvajanje glasbe – toda nam odpre možnost za naš DoS napad.



Slika 1: Nastavitve slušalk, ki dovoljujejo dvojno povezavo

Tako sem se najprej s telefonom povezal na slušalke, nato pa poskušal izvesti DoS napad z ukazom `l2ping`.

Najprej sem preizkusil ukaz:

```
l2ping -i hci0 -s 600 -f 2C:4D:79:78:2F:D7
```

Ta konstantno pošilja ping pakete z velikostjo 600 bajtov in čim manjšo

zakasnitvijo (to omogoča zastavica `-f`). Na ta napad so bile slušalke popolnoma odporne, saj imajo očitno dovolj procesorske moči, da odgovorijo na vsak tak ICMP (ping) paket. Zato je bilo treba napad izboljšati – to smo dosegli z multithreadingom, tj. z zagonom več takih ukazov hkrati. Pri tem smo si pomagali s python skripto `badblue.py`. Ta zažene 300 niti (threadov) z enakim ukazom kot prej in tako uspešno sesuje povezavo med telefonom in slušalkami.

Napad sem preizkusil tudi na telefonu OPPO Find X5 in Samsung Galaxy Ace S5830. Na OPPO Find X5 ni imel vpliva, medtem ko je imel Samsung Galaxy Ace S5830 velike težave z Bluetooth povezavo. Na moje ICMP pakete je odgovarjal z zamikom do 15000 ms oziroma 15 s, kar je povezavo naredilo praktično neuporabno.

5 Zaključek

Ali ste izpolnili cilje in možne nadaljne nadgradnje. Pri samem opisu rešitve se običajno sklicujemo na reference, npr. [1].

Literatura

[1] Web source. Cisco routers documentation. http://www.cisco.com/.